# Strong authentication and privileged access — KRL-ADM

Banque Kerlann (fictitious) · KRL-ADM — IAM administration console

Prepared by: **Attest (AI-assisted)**
Auditor sign-off: **pending**
Owner: **IT department — IAM team**
Date: **2026-11-04 10:21**
Run: **iam**

## 1. Executive summary

OPINION AT TESTING

**Unsatisfactory**

OPINION AFTER REMEDIATION

**Unsatisfactory**

**Basis for opinion**

7 controls tested (7 conclusive) against: DORA Art. 9(4) · RTS (EU) 2024/1774 Art. 12, 21 · PSI-4. Tests run on 2026-11-04 10:21, environment: Demonstration pre-production. The opinion rests solely on the verdicts of the deterministic test scripts and on the evidence sealed in the audit trail.

**Scope limitation:** Work programme and test scripts drafted by AI and not yet reviewed by an auditor; requirements needing document review or interview are not covered; the opinion applies at the test date only.

| | | | |
|---|---|---|---|
| **7** controls tested | **6** findings | **0** findings closed and verified · 5 re-tested compliant, closure pending approval | **1** open findings |
| **0** human approvals · 5 pre-approved (demo) | **8** sensitive data items masked in evidence | **1 min 13 s** audit duration | **$0.129 *** measured AI cost |



Critical: 1 High: 2 Medium: 3 Low: 0

### Key messages

- 6 findings across 7 controls: 1 critical, 2 high, 3 medium.
- 5 finding(s) re-tested compliant after a pre-approved change (not valid as an approval): closure pending owner approval, still counted in the opinion.
- 1 finding remains open, with an action plan, an owner and a due date.

## 2. Scope and method

| | |
|---|---|
| Engagement | AUD-2026-IAM-01 |
| Entity | Banque Kerlann (fictitious) |
| System | KRL-ADM — IAM administration console |
| System criticality | Supports critical or important functions (DORA) |
| Environment | Demonstration pre-production |
| Owner | IT department — IAM team |

| | |
|---|---|
| Lead auditor | Attest CI (automated run, no human auditor) |
| Date | 2026-11-04 10:21 |
| Framework | DORA Art. 9(4) · RTS (EU) 2024/1774 Art. 12, 21 · PSI-4 |
| Audited target | KRL-ADM IAM admin console (Banque Kerlann) |
| Work programme | existing catalogue reused · controls/AUD-2026-IAM-01.en.json |

## In scope

- Authentication and session settings of the KRL-ADM console
- Accounts with access to the console
- Logging of administrative actions

## Out of scope

- Intrinsic strength of MFA factors (robustness of authentication means)
- Central directory and identity federation
- Physical controls

## Method

1. Controls are derived from the framework (DORA, RTS 2024/1774, internal policy); severity is the one set by the policy.
2. Each test is a stored Python script, statically checked before execution (read-only) and run with a read-only service account.
3. The verdict comes from the script, never from the model. A screenshot is reviewed by Muse Spark to corroborate; on disagreement the control is flagged for review.
4. SAM 3.1 delineates the proving rows and the personal data, which is masked before distribution.
5. Every fix goes through a change request approved by the system owner, applied with a dedicated account, logged, then verified by the same test (DORA 9(4)(e)).
6. Every event and piece of evidence is sealed in a hash-chained audit trail (SHA-256).

## Limitations

- Tests cover the configuration reported by the system, not the actual strength of authentication factors.
- AI-drafted scripts and catalogue must be reviewed by an auditor before being considered validated.
- Fixes are drafted by the audit tool itself (self-review threat): closing a finding requires independent approval by the system owner.
- Fictitious entity and data: demonstration.

# 3. Findings overview

| REF. | RULE | TITLE | SEVERITY | TESTED | AFTER | STATUS | DUE DATE |
|---|---|---|---|---|---|---|---|
| F-01 | PSI-4.1 | Mandatory MFA for privileged accounts | Critical | Non-compliant | Compliant | Re-tested compliant — closure pending owner approval | 2026-12-04 |
| F-02 | PSI-4.2 | Mandatory MFA for users of critical system | High | Non-compliant | Compliant | Re-tested compliant — closure pending owner approval | 2027-02-02 |
| F-03 | PSI-4.7 | No generic or shared admin accounts | High | Non-compliant | | Action plan | 2027-02-02 |
| F-04 | PSI-4.3 | Strong password policy | Medium | Non-compliant | Compliant | Re-tested compliant — closure pending owner approval | 2027-05-03 |

| | | | | | | | |
|---|---|---|---|---|---|---|---|
| F-05 | PSI-4.4 | Account lockout after failed logins | Medium | Non-compliant | Compliant | Re-tested compliant — closure pending owner approval | 2027-05-03 |
| F-06 | PSI-4.5 | Inactive session timeout | Medium | Non-compliant | Compliant | Re-tested compliant — closure pending owner approval | 2027-05-03 |
| – | PSI-4.6 | Logging of administration actions | High | Compliant | | | |

## 4. Detailed findings and controls

### F-01 PSI-4.1 Mandatory MFA for privileged accounts

Critical · Non-compliant → Compliant

**Re-tested compliant — closure pending owner approval**

**CRITERIA**

MFA is enforced for all privileged admin accounts on KRL-ADM

PSI-4.1 · DORA 9(4)(d), RTS 21(1)(f)(ii)

**CONDITION**

Observed: `false`
Expected: `true`

GET /api/security returned mfa_admin=False.

**PROBABLE CAUSE**

Not established by the test: to be confirmed with the owner in the action plan (root-cause analysis).

**RISK**

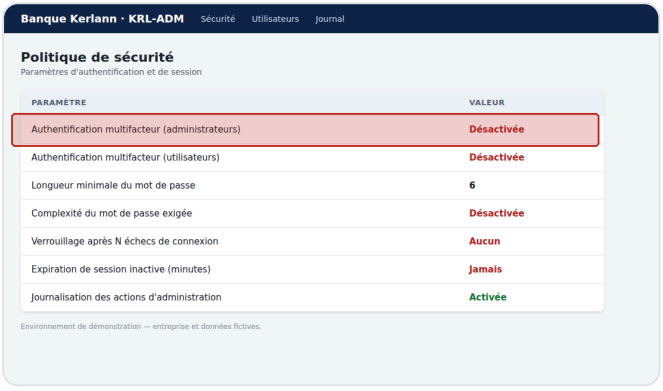
Without MFA for admins, stolen credentials allow full takeover of critical functions with no second barrier

**RECOMMENDATION**

Enable mandatory MFA for all privileged accounts by setting mfa_admin to true

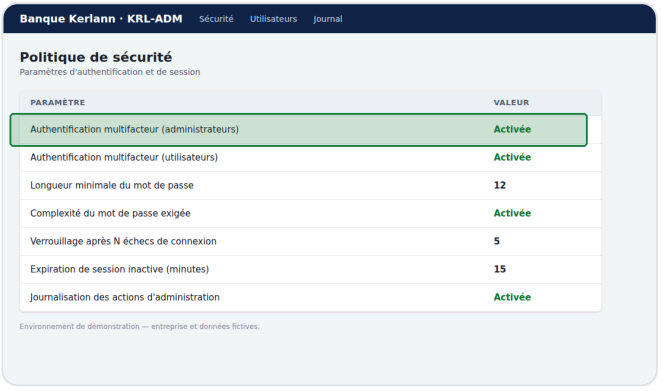
Due date: 2026-12-04 · Owner: IT department — IAM team

Test procedure: Retrieve the security configuration via GET /api/security and verify that mfa_admin is true




**At testing** — The screenshot corroborates the test. The security policy page shows administrator MFA as disabled, confirming mfa_admin is false.

2026-11-04 10:21:19 · SHA-256 67c44ebe64e7513c…




**After fix** — The screenshot corroborates the test. The screenshot shows MFA for administrators as Activée, matching the automated test result.

2026-11-04 10:22:06 · SHA-256 4d044106b76c9259…

> **Change request CHG-AUD-2026-IAM-01-01** · `PATCH /api/security {"mfa_admin": true}`
> Mandatory MFA for privileged accounts is required by control C1 and was observed as disabled.
> Expected impact: Admin users will be required to use MFA on next authentication.
> Approved by: **IAM owner (CI)** · 2026-11-04 10:21:53 · pre-approved (demo, not valid as an approval) · applied and logged
> System journal: 2026-11-04T10:21:53Z · svc-change · mfa_admin: False → True

## F-02 PSI-4.2 Mandatory MFA for users of critical system

High · Non-compliant → Compliant

**Re-tested compliant — closure pending owner approval**

### CRITERIA

MFA is enforced for standard users because KRL-ADM supports critical or important functions

PSI-4.2 · DORA 9(4)(d), RTS 21(1)(f)(ii)

### CONDITION

Observed: `false`
Expected: `true`

mfa_users is False.

### PROBABLE CAUSE

Not established by the test: to be confirmed with the owner in the action plan (root-cause analysis).

### RISK

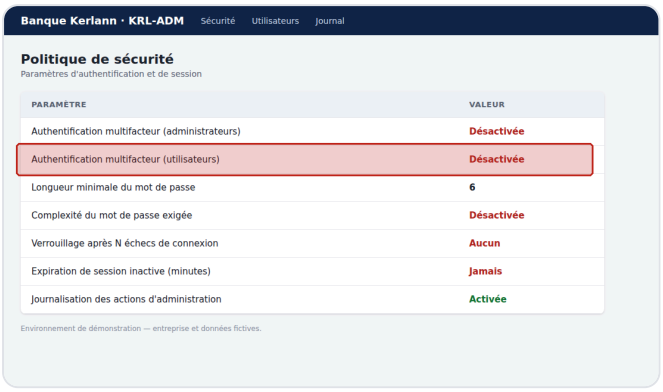
Without MFA for all users, compromised user credentials allow unauthorized access to critical functions

### RECOMMENDATION

Enable mandatory MFA for standard users by setting mfa_users to true

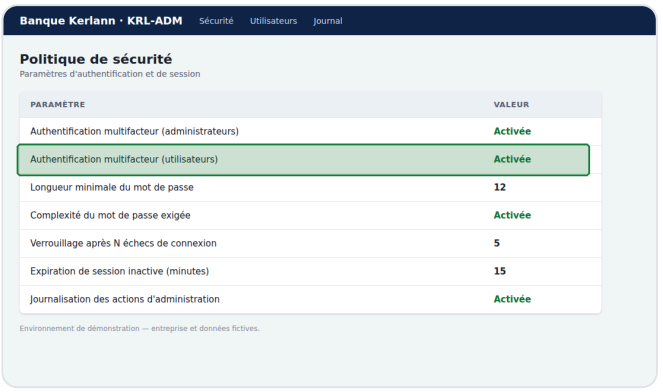
Due date: 2027-02-02 · Owner: IT department — IAM team

Test procedure: Retrieve the security configuration via GET /api/security and verify that mfa_users is true




**At testing** — The screenshot corroborates the test. The security policy table shows user MFA as Désactivée, confirming mfa_users is false.

`2026-11-04 10:21:17 · SHA-256 51c6e3e07f03478d…`




**After fix** — The screenshot corroborates the test. The screenshot shows MFA for standard users as Activée, matching the passing test.

`2026-11-04 10:22:08 · SHA-256 79fec875ddb3f0ac…`

> **Change request CHG-AUD-2026-IAM-01-02** · `PATCH /api/security {"mfa_users": true}`
> Mandatory MFA for standard users is required because KRL-ADM supports critical functions.
> Expected impact: Standard users will be required to use MFA at next login.
> Approved by: **IAM owner (CI)** · 2026-11-04 10:21:53 · pre-approved (demo, not valid as an approval) · applied and logged
> System journal: 2026-11-04T10:21:53Z · svc-change · mfa_users: False → True

## F-03 PSI-4.7 No generic or shared admin accounts

High · Non-compliant · Action plan

### CRITERIA

No account with role admin is generic or shared and every admin has a nominative login of the form initiale.nom with a personal email

PSI-4.7 · DORA 9(4)(c), RTS 21(1)(c), RTS 21(1)(e)(ii)

### CONDITION

Observed: `[{"login": "a.lefloch", "email": "a•••@kerlann-banque.example", "role": "admin"}, {"login": "ops", "email": "o•••@kerlann-banque.example", "role": "admin"}]`
Expected: `for all users where role == admin: login matches initiale.nom pattern and email is personal, with no function login and no shared mailbox`

1 of 2 admin account(s) violate nominative login or personal email requirements.

### PROBABLE CAUSE

### RISK

Not established by the test: to be confirmed with the owner in the action plan (root-cause analysis).

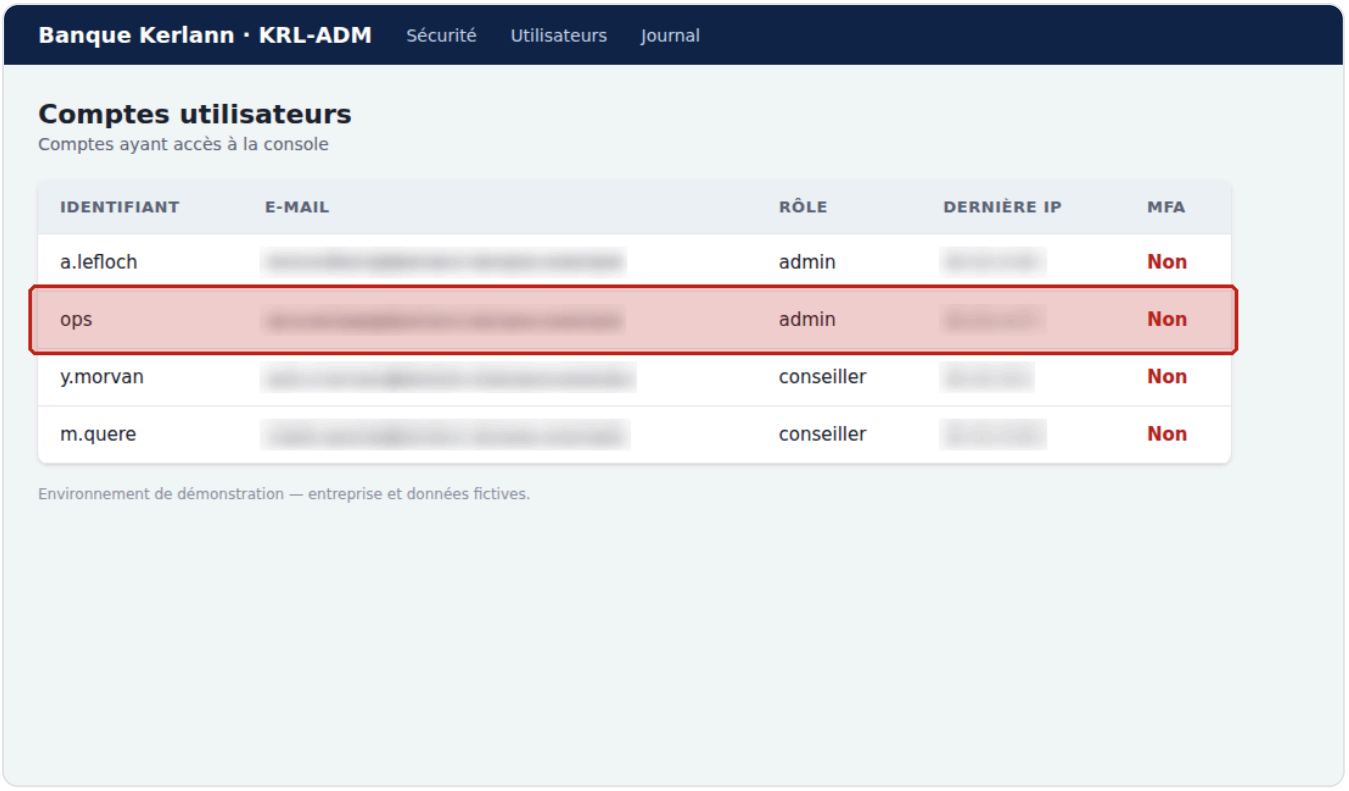
Generic or shared admin accounts destroy individual accountability and prevent attribution of privileged actions

**RECOMMENDATION**

Remove or disable generic and shared admin accounts and replace them with dedicated nominative accounts

Due date: 2027-02-02 · Owner: IT department — IAM team

Test procedure: Retrieve all accounts via GET /api/users and verify that every user with role admin has a nominative login and a personal email without function identifier or shared mailbox




**At testing** — The screenshot corroborates the test. The screenshot shows login 'ops' with role 'admin', which does not match the initiale.nom pattern. · 8/8 sensitive data items masked (0 spotted by the AI, the rest by the deterministic safety net)

`2026-11-04 10:21:39 · SHA-256 189759b0a7634155…`

**Manual remediation** · CHG-AUD-2026-IAM-01-03

The shared admin account ops violates nominative accountability and must be replaced with dedicated personal admin accounts.

1. Disable and remove the shared generic admin account login 'ops' with email 'o•••@kerlann-banque.example'
2. Provision dedicated nominative admin accounts of the form initiale.nom with personal email for each individual operator requiring admin privileges
3. Review /api/journal and /admin/journal for actions performed by 'ops' and re-attribute where possible, then re-verify via GET /api/users that all remaining admins meet nominative login and personal email requirements

## F-04 PSI-4.3 Strong password policy

Medium · Non-compliant → Compliant

**Re-tested compliant — closure pending owner approval**

**CRITERIA**

Passwords require a minimum length of 12 characters with complexity requirements enabled

PSI-4.3 · DORA 9(4)(d)

**CONDITION**

Observed: `{"password_min_length": 6, "password_require_complexity": false}`

Expected: `password_min_length >= 12 AND password_require_complexity == true`

password_min_length is 6 and password_require_complexity is False.

**PROBABLE CAUSE**

Not established by the test: to be confirmed with the owner in the action plan (root-cause analysis).

**RISK**

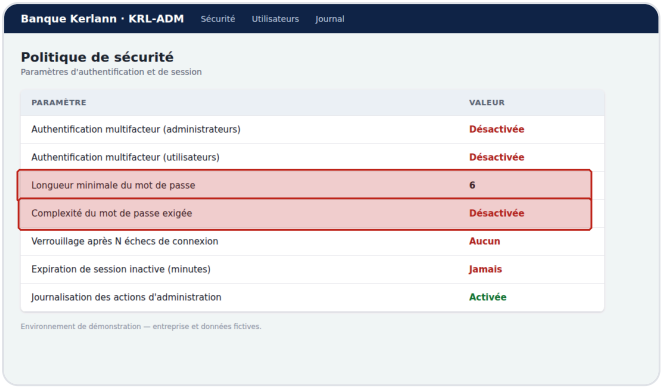
Weak or short passwords can be guessed or brute-forced, enabling unauthorized access to the system

**RECOMMENDATION**

Enforce a minimum password length of 12 characters with complexity by correcting the password settings

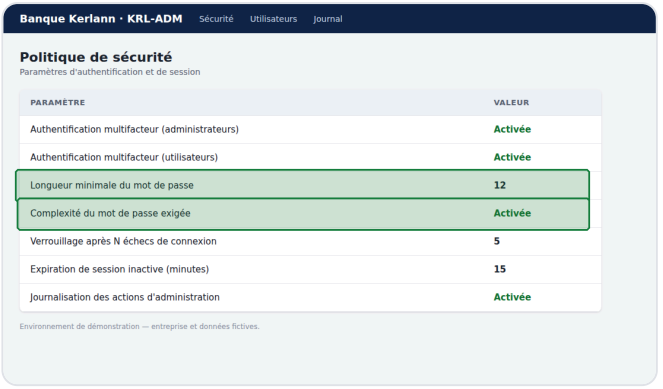
Due date: 2027-05-03 · Owner: IT department — IAM team

Test procedure: Retrieve the security configuration via GET /api/security and verify password_min_length and password_require_complexity




**At testing** — The screenshot corroborates the test. The screenshot shows minimum password length of 6 and complexity disabled, matching the failed test.

`2026-11-04 10:21:17 · SHA-256 c062444b25f45b37…`




**After fix** — The screenshot corroborates the test. The screenshot shows minimum password length 12 and password complexity enabled, matching the automated result.

`2026-11-04 10:22:05 · SHA-256 fa843810fb3c4f95…`

**Change request CHG-AUD-2026-IAM-01-04** · `PATCH /api/security {"password_min_length": 12, "password_require_complexity": true}`
Observed values of 6 and false do not meet the required policy of length >=12 with complexity enabled.
Expected impact: Users will be required to use passwords of at least 12 characters with complexity on next password creation or change.
Approved by: **IAM owner (CI)** · 2026-11-04 10:21:53 · pre-approved (demo, not valid as an approval) · applied and logged
System journal: 2026-11-04T10:21:53Z · svc-change · password_min_length: 6 → 12; password_require_complexity: False → True

## F-05 PSI-4.4 Account lockout after failed logins

Medium · Non-compliant → Compliant

**Re-tested compliant — closure pending owner approval**

**CRITERIA**

Accounts lock after at most 5 failed login attempts and lockout is never disabled

PSI-4.4 · DORA 9(4)(c)

**CONDITION**

Observed: `0`
Expected: `lockout_threshold >= 1 AND lockout_threshold <= 5`
lockout_threshold is 0, which is outside the required range 1 to 5 inclusive.

**PROBABLE CAUSE**

Not established by the test: to be confirmed with the owner in the action plan (root-cause analysis).

**RISK**

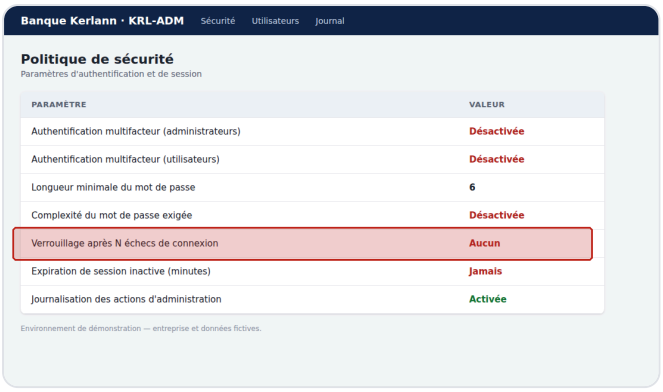
Without lockout, attackers can perform unlimited password-guessing attacks against accounts

**RECOMMENDATION**

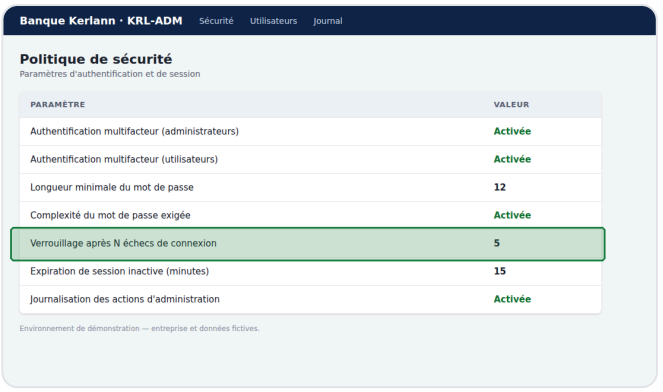
Configure account lockout to 5 attempts at most by setting lockout_threshold between 1 and 5

Due date: 2027-05-03 · Owner: IT department — IAM team

Test procedure: Retrieve the security configuration via GET /api/security and verify that lockout_threshold is between 1 and 5 inclusive




**At testing** — The screenshot corroborates the test. The screenshot shows lockout after failed logins as Aucun, confirming lockout is disabled.
`2026-11-04 10:21:20 · SHA-256 013a9eceeb05ebc4…`




**After fix** — The screenshot corroborates the test. The screenshot shows lockout after 5 failed attempts, matching the automated test observed value of 5.
`2026-11-04 10:22:06 · SHA-256 28c1278e18b20ef1…`

> **Change request CHG-AUD-2026-IAM-01-05** · `PATCH /api/security {"lockout_threshold": 5}`
> Setting lockout_threshold from 0 to 5 restores account lockout within the required 1 to 5 range to limit password-guessing attacks
> Expected impact: Users will be locked out after 5 consecutive failed logins and will require standard unlock assistance
> Approved by: **IAM owner (CI)** · 2026-11-04 10:21:53 · pre-approved (demo, not valid as an approval) · applied and logged
> System journal: 2026-11-04T10:21:53Z · svc-change · lockout_threshold: 0 → 5

## F-06 PSI-4.5 Inactive session timeout

Medium · Non-compliant → Compliant

**Re-tested compliant — closure pending owner approval**

### CRITERIA

Inactive sessions expire after at most 15 minutes and expiration is never disabled

PSI-4.5 · DORA 9(4)(c)

### CONDITION

Observed: `0`

Expected: `session_timeout_minutes >= 1 AND session_timeout_minutes <= 15`

Observed session_timeout_minutes is 0, outside the required 1 to 15 inclusive.

### PROBABLE CAUSE

Not established by the test: to be confirmed with the owner in the action plan (root-cause analysis).

### RISK

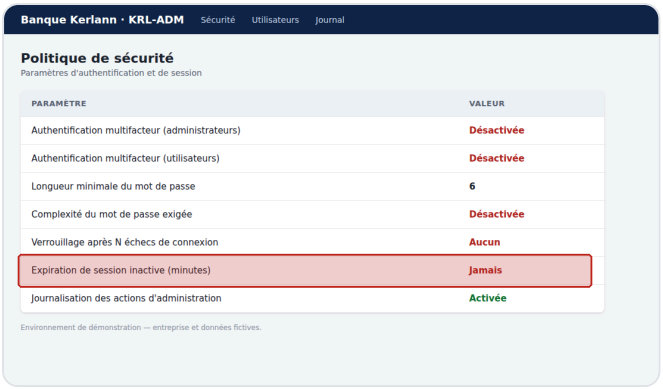
Unlimited inactive sessions allow session hijacking and unauthorized use of unattended workstations

### RECOMMENDATION

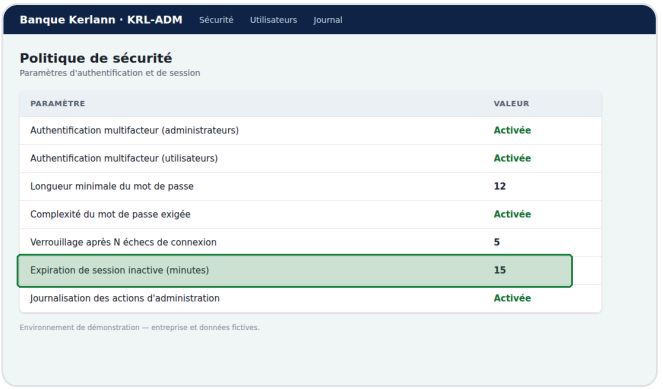
Enforce inactive session expiration at 15 minutes at most by setting session_timeout_minutes between 1 and 15

Due date: 2027-05-03 · Owner: IT department — IAM team

Test procedure: Retrieve the security configuration via GET /api/security and verify that session_timeout_minutes is between 1 and 15 inclusive




**At testing** — The screenshot corroborates the test. The screenshot shows inactive session expiration set to Jamais, confirming the timeout is disabled.
`2026-11-04 10:21:32 · SHA-256 cf849ac4c0e6af60…`



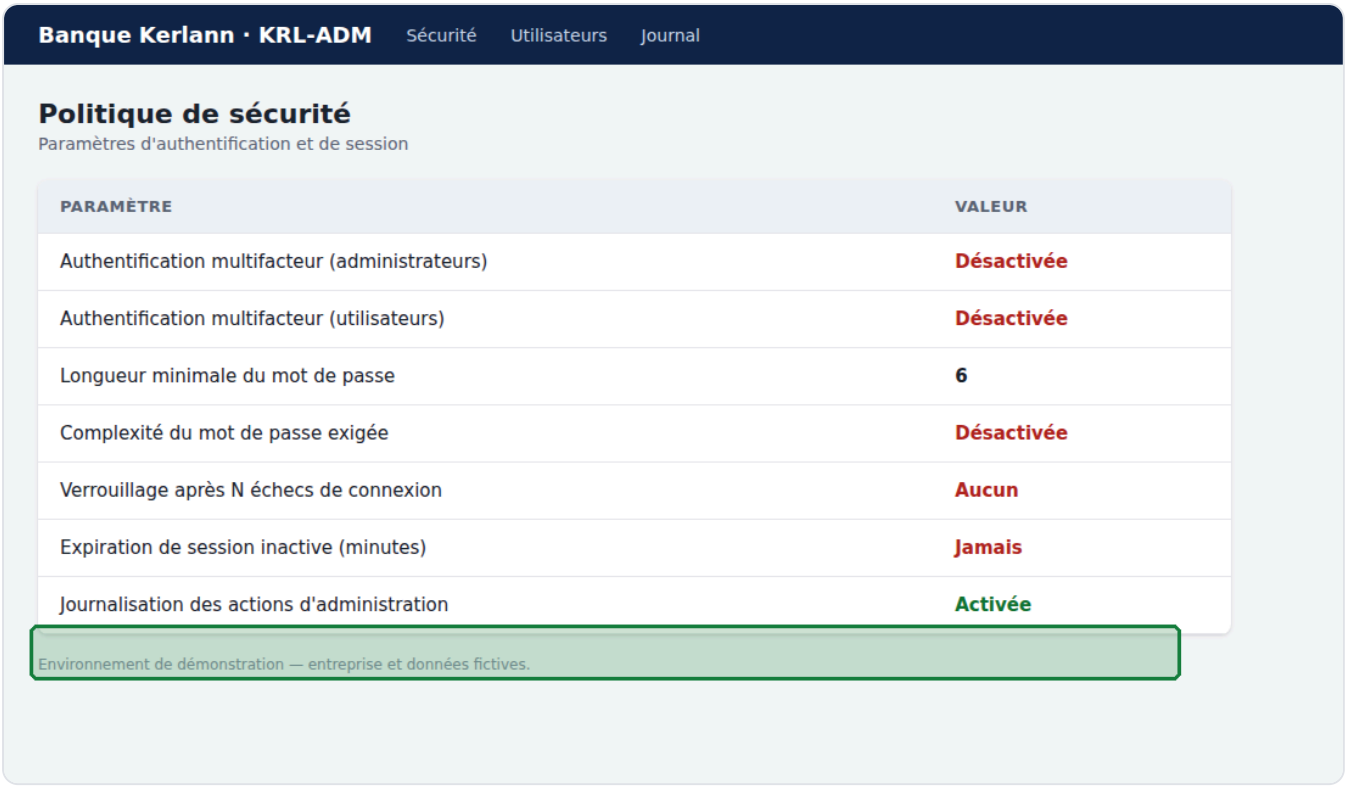

**After fix** — The screenshot corroborates the test. The screenshot shows inactive session expiration set to 15 minutes, matching the automated result.
`2026-11-04 10:22:15 · SHA-256 9b2e80aae3801393…`

> **Change request CHG-AUD-2026-IAM-01-06** · `PATCH /api/security {"session_timeout_minutes": 15}`
> Observed value 0 disables expiration and violates the required 1 to 15 minute range, so set it to the maximum allowed 15 minutes.
> Expected impact: Inactive sessions will expire after 15 minutes and require re-authentication.
> Approved by: **IAM owner (CI)** · 2026-11-04 10:21:53 · pre-approved (demo, not valid as an approval) · applied and logged
> System journal: 2026-11-04T10:21:53Z · svc-change · session_timeout_minutes: 0 → 15

## `PSI-4.6` Logging of administration actions

High · Compliant

Compliant control — All administration actions are logged · RTS 12(2)(c)(i)
Observed: `true`




**At testing** — The screenshot corroborates the test. The screenshot shows admin action logging as Activée, matching the automated pass result.

`2026-11-04 10:21:31 · SHA-256 35ca60e220376cd6…`

# Appendices

## A. Traceability matrix

| REQUIREMENT | RULE | CONTROL | SCRIPT (SHA-256) | RESULT |
|---|---|---|---|---|
| DORA 9(4)(d), RTS 21(1)(f)(ii) | PSI-4.1 | C1 · Mandatory MFA for privileged accounts | 098d37cd0158dd1a · script library (reused) | Non-compliant → Compliant |
| DORA 9(4)(d), RTS 21(1)(f)(ii) | PSI-4.2 | C2 · Mandatory MFA for users of critical system | fa35c17fbb1dfdd3 · script library (reused) | Non-compliant → Compliant |
| DORA 9(4)(d) | PSI-4.3 | C3 · Strong password policy | b440a5b4dc6b0fb3 · script library (reused) | Non-compliant → Compliant |
| DORA 9(4)(c) | PSI-4.4 | C4 · Account lockout after failed logins | 10d2a8f06337b5bc · script library (reused) | Non-compliant → Compliant |
| DORA 9(4)(c) | PSI-4.5 | C5 · Inactive session timeout | 4157e9750f010f98 · script library (reused) | Non-compliant → Compliant |
| RTS 12(2)(c)(i) | PSI-4.6 | C6 · Logging of administration actions | e2f3534909210977 · script library (reused) | Compliant |
| DORA 9(4)(c), RTS 21(1)(c), RTS 21(1)(e)(ii) | PSI-4.7 | C7 · No generic or shared admin accounts | 5e917770866b8e47 · script library (reused) | Non-compliant |

## B. Evidence register

| FILE | | | SHA-256 |
|---|---|---|---|
| evidence/C1_before.png | C1 · At testing | 2026-11-04 10:21:19 | 67c44ebe64e7513cff1994ab0858a075d03e76c1e58f8a55df155258b24f92b7 |
| evidence/C1_after.png | C1 · After fix | 2026-11-04 10:22:06 | 4d044106b76c9259bd130c346a0d27275354229a780ee4acbbc0f4b7c14a1764 |
| evidence/C2_before.png | C2 · At testing | 2026-11-04 10:21:17 | 51c6e3e07f03478d7510b087bcd4ab18459809a61af31282915e186ae93948df |
| evidence/C2_after.png | C2 · After fix | 2026-11-04 10:22:08 | 79fec875ddb3f0ac068b050ba38353d01e862e1f6d13d8ee7fc9823d45e74502 |
| evidence/C3_before.png | C3 · At testing | 2026-11-04 10:21:17 | c062444b25f45b3730865ae70aa5304ace226677a2ba4b7d08c33e3fe49cabc3 |
| evidence/C3_after.png | C3 · After fix | 2026-11-04 10:22:05 | fa843810fb3c4f950cc510796babb38671ad5c581fe4610f053807f46b88de00 |
| evidence/C4_before.png | C4 · At testing | 2026-11-04 10:21:20 | 013a9eceeb05ebc41dc91f9e1f7fb05196b9a54977b326825a0609642d5e84c8 |
| evidence/C4_after.png | C4 · After fix | 2026-11-04 10:22:06 | 28c1278e18b20ef1f9e1725d26d439e7e5462f23f8af7a95a7f21aee082e5599 |
| evidence/C5_before.png | C5 · At testing | 2026-11-04 10:21:32 | cf849ac4c0e6af60ee927ac6ea9a82fcc46e4946579f2d8a697afe5202d01b11 |
| evidence/C5_after.png | C5 · After fix | 2026-11-04 10:22:15 | 9b2e80aae38013933c96870042148fd73b1cb0445a31a58bf72d9febaca7f645 |
| evidence/C6_before.png | C6 · At testing | 2026-11-04 10:21:31 | 35ca60e220376cd6c666e60bff9191c14b3a8d556196ba1ccf5c04354e270e1c |

| | | | |
|---|---|---|---|
| evidence/C7_before.png | C7 · At testing | 2026-11-04 10:21:39 | 189759b0a7634155538ec454f0923726f341c868462178e9500fc16d2d05c94b |
| evidence/journal.png | System journal | | d6b66ecfeebfb47a303197e5079ff69b4b99639849d8f9f4a7fffa192c1db8ad |

## C. AI usage, costs and human oversight

| MODEL | CALLS | INPUT TOKENS | OUTPUT TOKENS | IMAGES | COST (USD) |
|---|---|---|---|---|---|
| muse-spark-1.3 | 18 | 22,593 | 23,625 | 0 | 0.1286 |
| sam-3.1 | 12 | 0 | 0 | 12 | price not published |
| **Total** | | | | | **0.1286** |

Sensitive data (personal data and secrets) in evidence: 0/8 spotted by Muse Spark + SAM, 8/8 masked in the end thanks to the deterministic safety net (page text).

* sam-3.1: price not published (pricing.toml)

## Human decisions

| TICKET | REF. | | APPROVED BY | MODE | DATE |
|---|---|---|---|---|---|
| CHG-AUD-2026-IAM-01-01 | F-01 | ✔ | IAM owner (CI) | pre-approved (demo, not valid as an approval) | 2026-11-04 10:21:53 |
| CHG-AUD-2026-IAM-01-02 | F-02 | ✔ | IAM owner (CI) | pre-approved (demo, not valid as an approval) | 2026-11-04 10:21:53 |
| CHG-AUD-2026-IAM-01-04 | F-04 | ✔ | IAM owner (CI) | pre-approved (demo, not valid as an approval) | 2026-11-04 10:21:53 |
| CHG-AUD-2026-IAM-01-05 | F-05 | ✔ | IAM owner (CI) | pre-approved (demo, not valid as an approval) | 2026-11-04 10:21:53 |
| CHG-AUD-2026-IAM-01-06 | F-06 | ✔ | IAM owner (CI) | pre-approved (demo, not valid as an approval) | 2026-11-04 10:21:53 |

## Safeguards

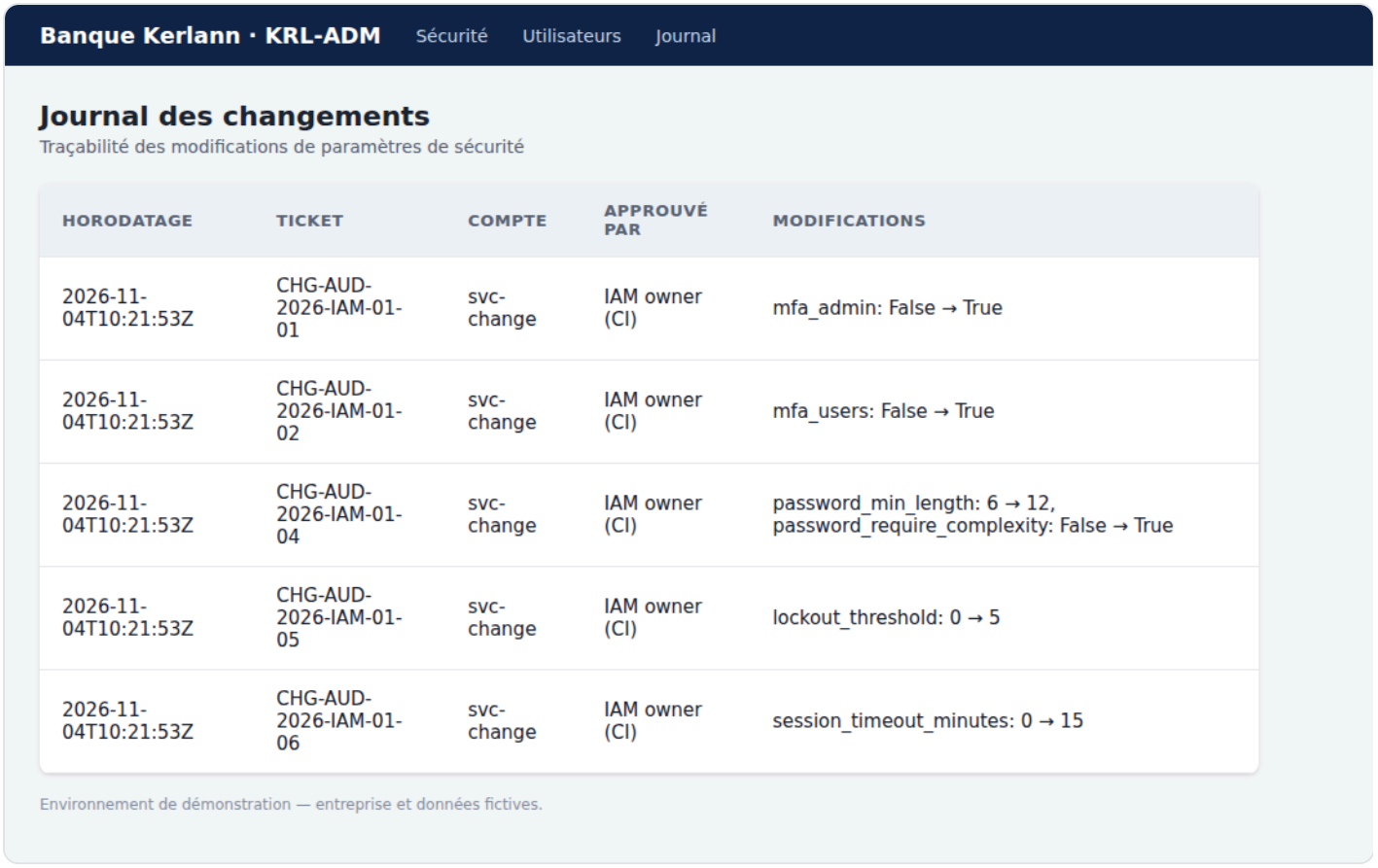
- Scripts: allow-listed imports, no write requests (static analysis before execution).
- Read-only test account: any write would be refused by the system (defence in depth).
- Fixes: allow-listed route and parameters, human approval, separate change account.
- Segregation of duties: the approver cannot be the auditor.

## D. Integrity

Audit-trail fingerprint when the report was issued. Verify with `python -m attest verify <folder>`.

45a1d072229f4f423d2134d6de84be50a10b5acb26cd91c5a4961ee0f9676abf

## E. Change log of the audited system




SHA-256 d6b66ecfeebfb47a303197e5079ff69b4b99639849d8f9f4a7fffa192c1db8ad